

Compliance Requirements From "High Risk Systems" As Per the EU AI Act

Summary Report For AI Recruitment Systems

Waleed Ahmed

September 10, 2026

1 Introduction

The [Regulation \(EU\) 2024/1689](#), or more commonly known as the EU AI Act 2024 is a legal frame for the Artificial Intelligence (AI). It regulates the AI based on its potential to do harm and not the technology itself. It is unlike the GDPR framework as it applies globally to all the companies if the AI based outputs are utilised or deployed within the EU.

It is a 4 Tier framework where there are 4 risk based classes:

(i) **High-Risk (Prohibited)**

Systems which can pose a threat to safety, livelihood, or rights are banned entirely. Such as untargeted scraping of facial images, social scoring systems, emotional regulation in workplace / interviews.

(ii) **High-Risk (Strictly Regulated)**

Systems which significantly affect the life trajectory of an individual. HR, recruitment, ATS software which are used to filter and rank candidates.

(iii) **Limited-Risk (Transparency Obligations)**

Systems like conversational chatbots. Customer service chatbots etc. Primary mandate is clear user disclosure; Humans must be informed that they are interacting with an AI.

(iv) **Minimal-Risk (Unregulated)**

Most AI applications currently in use. Video games AI, spam filters, inventory prediction algorithms etc.

2 Compliance of High Risk Systems - Recruitment Systems

According to [Chapter III \(Articles 9-15\)](#) discuss the following required capabilities that are needed to be implemented in order for a high-risk system to be compliant.

2.1 (Article 9) Continuous Risk Management

A documented and structured process that identifies, estimates, and mitigates the known risks (such as algorithmic bias or technical errors) throughout the operational lifecycle.

2.2 (Article 10) Data Governance & Bias Mitigation

The training, validation, and testing datasets must meet high-quality standards. The datasets must be thoroughly reviewed for historical biases (e.g., gender or racial discrimination in historical hiring data) and corrected before deployment.

2.3 (Article 11) Exhaustive Technical Documentation

The provider must create and maintain up-to-date technical blueprints showing exactly how the model works, how it was trained, and its structural architecture so regulators can audit it.

2.4 (Article 12) Automated Logging

The system must automatically generate and store immutable logs of its operations. For recruitment, it must log every single input, output, and decision point (e.g., why a specific candidate was automatically rejected or ranked low).

2.5 (Article 13) Transparency & Disclosures

The system must be clear and understandable to the corporate users (HR managers). It must provide a manual or explicit guide outlining its intended purpose, limits, and how it calculates scores.

2.6 (Article 14) Human Oversight

The software must be designed so that humans can fully understand its outputs, override decisions, or disregard the AI's recommendations completely.

2.7 (Article 15) Robustness and Cyber-security

The system must maintain appropriate levels of accuracy and be resilient against "adversarial attacks" (e.g., candidates trying to game the AI with hidden keywords).

2.8 (Article 17, 48) Quality Management System & CE Marking

The company must implement a product-focused compliance governance workflow, complete a formal Conformity Assessment, and affix a CE Mark to the software.

3 Determination of Compliance Costs

Compliance costs are determined by a mix of upfront development friction and long-term operation overhead. For a software provider, these costs typically scale based on three major factors:

3.1 Architecture and System Complexity (*The Tech Stack*)

3.1.1 Black Box Models (*Most Expensive*)

Deep neural networks or fine-tuned Large Language Models (LLMs) have massive data lineage webs. Documenting every node weight and proving why a model inferred a specific match requires expensive third-party automated auditing platforms, data engineers, and endless drift-retraining cycles.

3.1.2 Hybrid or Highly Explainable Models (*Medium Cost*)

Built from the ground up to map transparent semantic logic, these systems have lower testing and documentation overhead because their logic paths are traceable by design.

3.1.3 Purely Deterministic Systems (*Near-Zero Cost*)

If a system matches entirely on user-defined parameters, logic filters, and explicit test metrics, it escapes the "High-Risk AI" definition completely, eliminating these compliance costs entirely.

3.2 The Legal and Procedural Chain

3.2.1 Conformity Assessments

For standalone recruitment systems under Annex III, providers can usually perform a self-assessment rather than paying a third-party "Notified Body" audit. However, compiling the necessary Annex IV documentation requires hundreds of billable internal engineering and legal hours.

3.2.2 Fundamental Rights Impact Assessments (FRIAs)

For corporate deployers using the tech, additional legal assessments must be carried out to prove the software doesn't infringe on labour rights.

3.3 The Risk of Non-Compliance (*The Alternative Cost*)

The true metric driving compliance budgets is the penalty tier. If an ATS or recruitment platform is found operating non-compliantly after the high-risk enforcement deadlines kick in, the fines are catastrophic:

- Up to **€15 million or 3% of global annual turnover** (whichever is higher) for violating high-risk technical obligations.
- Up to **€35 million or 7% of global turnover** if the system crosses into prohibited practices.